INDEPENDENT TECHNICAL REVIEW

IWACU RWANDA 2

Production Readiness Audit & Release-Gate Report

A read-only audit of the connected GitHub repository, the live Supabase project metadata and database, and Vercel deployment configuration.

AUDIT DATE	30 October 2026
GITHUB	eddyizere24-collab/Iwacu-rwanda-2
SUPABASE	iwacu-rwanda-2 / ref buexgewxypvkqmphvfec
VERCEL	iwacu-rwanda-2 / latest inspected deployment is a branch Preview
AUDIT MODE	Read-only. No files, settings, deployments, or database records were modified.

RELEASE DECISION: NO-GO

The available evidence does not support a claim that the platform is 100% complete or production-ready. Critical prerequisites remain, especially real verified leader records, branch/deployment alignment, release-target verification, and end-to-end validation.

1. Executive verdict

NO-GO FOR A PUBLIC PRODUCTION LAUNCH. The database contains 17,423 valid-looking administrative boundary rows but ZERO active leader records. The latest Vercel deployment inspected is marked READY, yet its target is null, its project metadata reports live=false, and it was built from a security Preview branch rather than main. These are separate blockers; one does not cancel the other.

What this audit actually verifies

This review inspected connected platform metadata and source artifacts directly: GitHub repository metadata, default-branch files, branch comparison, commit history and Actions runs; Supabase project metadata, migrations, public table counts/columns, database policies, grants, views, functions, triggers, integrity aggregates and database advisors; and Vercel project, latest deployment, domain metadata and environment-variable metadata. Public official government sources were checked for emergency numbers and NISR boundary coverage. This is stronger than accepting an AI-generated summary, but it is not a substitute for runtime browser tests or a formal independent penetration test.

Release readiness by dimension

Dimension	Observed state	Decision
Core public value	0 active leader records; the directory cannot display verified real leaders from this database.	**BLOCKED**
GitHub release source	main is 117 commits behind security/part-2-auth-hardening.	**BLOCKED**
Vercel production	Latest inspected deployment is READY but target=null; project metadata says live=false.	**UNPROVEN**
Database structure	17,423 boundary rows; one root, no orphan parents and no invalid/empty active geometries in the checked query.	**PROMISING**
Admin security	Security branch improves Supabase Auth and scope checks; main still has a legacy token gate.	**BRANCH DRIFT**
AI feature claim	Current API route is heuristic + NISR GIS lookup; no LLM call found in the audited ai-router route.	**MISLABELLED**
Offline/PWA	Manifest references icons absent from the repository; bundled offline GeoJSON is empty.	**BLOCKED**

Meaning of '100% ready'

No production system can honestly be certified as 100% risk-free. The practical gate is: every P0 is closed, all P1 security/data issues have documented mitigations, required tests pass against the exact production commit and configuration, official data is verified, rollback and recovery are rehearsed, and the owner signs off on known residual risks.

2. Highest-priority findings

The following are the release blockers in the order they should be resolved. Each includes evidence and a verifiable acceptance criterion in the detailed sections below.

Priority	Finding	Why it matters
P0	Zero current leader records	The main service promise - discovering and contacting actual leaders - cannot be fulfilled from the live database.
P0	No demonstrated production release target	Vercel shows a branch Preview and no production target in the inspected deployment metadata.
P0	Main branch is 117 commits behind the audited security branch	Main contains older admin gate, reports, health checks and emergency labels; the latest Preview does not make main equivalent.
P1	Boundary dataset provenance/coverage must be reconciled	Supabase counts 14,823 village rows; the referenced NISR 2022 service describes 14,816 mapped villages out of 14,837 gazetted.
P1	No real LLM-backed AI is evidenced	UI says AI, but the inspected endpoint performs token-based place search against NISR; no Gemini/Groq generation call is present in the route.
P1	Credential and authentication hardening	Supabase leaked-password protection is disabled; Vercel flags some secret metadata as readable-secret and secrets are configured for multiple targets.
P1	Offline/PWA completion gap	The offline GeoJSON has zero features and manifest icon files are missing.
P1	Emergency number mappings in main are wrong	Main labels 113 as fire, 114 as traffic, and 3512 as health information; official Rwanda sources list 111 fire, 113 traffic, 3512 GBV.

Notably positive evidence

• Supabase project status is ACTIVE_HEALTHY; PostgreSQL 17.11 and PostGIS are installed.

• The checked active boundary geometries had no invalid or empty geometry flags; parent references had no orphan count in the aggregate audit.

• The database has RLS enabled and direct browser table grants are restricted; the public leader view excludes phone_number and has security_invoker=true.

• A security-branch CI run passed TypeScript typecheck, authorization tests, production build and limited Preview API smoke checks. This does not prove full feature correctness.

3. GitHub source control and Vercel release integrity

3.1 Repository state

Repository: eddyizere24-collab/Iwacu-rwanda-2. Default branch: main. Main commit at inspection: **c6c01cbd3a24fea53df7f0fe1b0600dca58e137b** (29 October 2026, 'fix(security): keep raw phone out of leader conflict responses').

The branch comparison reports security/part-2-auth-hardening is 117 commits ahead and 0 behind main, at SHA **94ff01f598356991e841e0cb43a05def0b5a6a5a**. The latest inspected Vercel deployment was built from that security branch. This creates a split between the default source developers normally see and the source currently used by the latest Preview deployment.

Important changes present on the security branch but not main include the updated Supabase Auth-backed admin gate and scope-check helper, persistent Supabase-backed inactive-number reports, safer public health endpoint behavior, the privacy page, database security migrations, browser hardening headers and automated security tests. Merge this work only after a reviewed PR, conflict resolution, all checks passing and schema compatibility review; do not force-push or blindly copy files.

3.2 CI and repository controls

CRITICAL / GH-01 The release source is not unified

Evidence: GitHub API comparison: 117 commits of divergence; latest Vercel deployment metadata points to `security/part-2-auth-hardening`, not `main`.

Impact: A future deployment from main can omit fixes that currently work in Preview, while Preview can give a false sense that the default branch is ready.

Required action: Create a reviewed pull request to bring the intended security branch into main. Re-run CI on the final merge commit and pin Vercel production to that exact SHA.

Acceptance test: The main branch SHA equals the reviewed release commit or is its tested descendant; a fresh production deployment reports the same repository, branch and SHA.

HIGH / GH-02 Default branch protection is not enabled

Evidence: GitHub branch metadata explicitly returned `protected: false` for main. The repository is public.

Impact: Accidental direct pushes can change the release branch without mandatory review or checks.

Required action: Enable main branch protection: require pull requests, required status checks, no force pushes, no deletion and review of security-sensitive changes. Review access to all repository collaborators and Actions permissions.

Acceptance test: A read-only GitHub branch/ruleset inspection confirms protection and required checks; a test PR cannot merge while checks are failing.

HIGH / GH-03 CI is limited and dependency installation is not deterministic

Evidence: The security workflow runs `npm install`, `npm run typecheck`, `npm run test:security`, `npm run build` and three Preview API checks. The repository tracks `bun.lock`; the inspected manifest has no `package-lock.json` in the tree listing. CI does not run lint, browser E2E, accessibility, vulnerability or full integration tests.

Impact: A passing build can still ship broken search, GPS, admin workflows, broken data relationships or unsafe UI. Installing from ranges without a checked-in npm lockfile can resolve a different dependency tree on later runs.

Required action: Choose one package manager and commit its lockfile. Use the matching frozen/ci install command. Add lint, unit/integration tests, route tests, Playwright or equivalent E2E, dependency/security scan, and production smoke tests.

Acceptance test: Clean CI installs the locked dependency graph and runs typecheck, lint, unit/security tests, database contract tests, build and critical browser journeys successfully.

3.3 Vercel status

Project metadata: Vercel project dashboard; project ID `prj_tB8EY3aJ37ObcXpHea3o7jFLZbUt`, framework Next.js, Node 24.x, and `live=false`. Latest inspected deployment ID `dpl_AoLWpAsabxNpwQihe9jHG1WgWVMD` is `READY`, but `target=null`, and the alias returned was branch-specific: `iwacu-rwanda-2-git-security-part-2-auth-hardening-ahabona.vercel.app`. The project metadata lists `iwacu-rwanda-2.vercel.app` among project domains, but the latest deployment was not evidenced as a Production-targeted deployment.

This audit environment could not independently load the public deployed page for browser-based testing. Therefore, HTTP status, screen layout and actual interactive behavior on the live domain remain unverified in this report. `READY` is a deployment state, not proof that the product is fully ready or serving the intended version to the public.

CRITICAL / VER-01 Production release/promotion is not demonstrated

Evidence: Latest deployment is READY with `target=null`, branch `security/part-2-auth-hardening`, and project metadata `live=false`; only a branch-preview alias is reported for that deployment.

Impact: The owner cannot confidently tell which commit a citizen is using or whether the intended domain serves the audited version.

Required action: After merge and full testing, deploy the reviewed main SHA to Vercel Production, verify the intended domain is attached, and preserve the prior stable deployment for rollback.

Acceptance test: Vercel shows target `production`, correct `main` release SHA, verified domain and successful production health plus functional smoke tests from an external browser.

4. Supabase: live data, schema and spatial integrity

Project: iwacu-rwanda-2 Supabase dashboard. Project ref `buexgewxypvkqmphvfec`; region `eu-central-1`; status `ACTIVE_HEALTHY`; PostgreSQL 17.11; PostGIS 3.3.7. Sixteen migrations were listed as applied. Audit SQL was read-only.

4.1 Current public-table inventory

Table	Rows	Interpretation
public.boundaries	**17,423**	Country, province, district, sector, cell and village hierarchy. RLS enabled.
public.leaders	**0**	Zero active leader data: the main public directory capability is not populated.
public.admin_profiles	**1**	One admin profile; aggregate query found one super-admin profile. Identity and least-privilege access still require functional test.
public.audit_logs	**0**	No entries at audit time. Logging of privileged actions has not been demonstrated.
public.inactive_number_reports	**0**	Durable report table exists; no reports are currently stored.
public._bak_boundaries_geom	**17,423**	Backup table with no primary key and no RLS policy; advisor flags it. Current grants show service_role use; review retention and access.
public._bak_boundaries_meta	**1**	Backup metadata table with no primary key and no RLS policy; advisor flags it.

4.2 Boundary level counts and integrity

Level	Count	Checked result
Country	1	1 active root
Province	5	All active
District	30	All active
Sector	416	All active
Cell	2,148	All active
Village	14,823	All active; unique scope codes

- Active roots: 1; orphan parent references: 0; active children with inactive parents: 0.
- Bad active geometries (null/empty/invalid): 0 in the queried aggregate.
- All 17,423 rows were active; `scope_code` values were unique within each level in the count query.

These results support structural consistency of the current database sample, but do not verify every polygon against field GPS observations or certify the official accuracy/currentness of each boundary.

4.3 Coverage/source discrepancy

The repository's own documentation and official NISR layer metadata say the Village Boundary 2022 dataset mapped 14,816 of 14,837 gazetted villages and has known coverage exclusions. The live Supabase table contains 14,823 village rows - seven more than that stated mapped count. That discrepancy may have an explainable source/version cause, but the project currently needs an auditable import manifest and reconciliation instead of claiming full national completeness. Official layer: NISR Village Boundary 2022 metadata.

CRITICAL / DB-01 The leaders table is empty

Evidence: Read-only live query: `public.leaders` row count = 0 and active leaders = 0. `v_active_leaders` returns only rows backed by that table.

Impact: Name/place lookup may identify an administrative unit, but no real official's name/contact can be returned from the database. The main public promise is therefore incomplete.

Required action: Obtain/approve an authoritative leader register. For every record, verify identity, role, jurisdiction code, current term, contact permission, provenance and last verification date; import through a logged/reviewed process. Do not seed fake officials or treat mock fixtures as real data.

Acceptance test: A defined pilot geography has the expected count of approved leaders; every leader links to a valid active boundary; a responsible official signs off on a sample reconciliation; public endpoint returns only active verified records with appropriately masked phone numbers.

HIGH / DB-02 Boundary source provenance and national coverage are not reconciled

Evidence: Database reports 14,823 village rows; official NISR 2022 layer metadata reports 14,816 mapped of 14,837 gazetted and identifies known gaps/exclusions.

Impact: GPS can return plausible but missing or stale administrative units; public wording can overstate precision or coverage.

Required action: Run a source-to-database reconciliation using official feature identifiers, import timestamp, source URL/version, checksums, duplicate checks and missing-feature list. Record unrepresented villages and source coverage limitations in user-facing language.

Acceptance test: A machine-readable import report proves counts reconcile to an identified official source snapshot, enumerates all gaps, and a field test covers urban, rural, edge and known excluded areas.

HIGH / DB-03 Audit logging is not demonstrated

Evidence: `audit_logs` currently has zero rows. Live trigger inspection found only `set_updated_at` triggers on boundaries, leaders and admin_profiles, not audit-event triggers; no explicit application insert path was found in the inspected routes/schema search.

Impact: Sensitive profile/contact changes, failed admin attempts and report resolutions may lack a reliable forensic trail.

Required action: Implement server-side, tamper-resistant audit events for admin login outcome, leader create/update/deactivate, reveal-phone access, report resolution, boundary imports and permission denials. Do not log raw secret values or full phone numbers unnecessarily.

Acceptance test: A scripted admin change creates a traceable audit row with actor, timestamp, action, scope, record ID and minimal before/after data; browser clients cannot forge, edit or delete those records.

5. Security and privacy review

5.1 Controls observed

• RLS is enabled on boundaries, leaders, admin_profiles, audit_logs, inactive_number_reports and the two backup tables.

• Browser roles do not have direct base-table privileges for main restricted tables in the inspected grants; the public `v_active_leaders` view uses `security_invoker=true` and excludes `phone_number`.

• Current database policies use private helper functions for current administrator scope and super-admin identity. The security branch's application helper compares complete scope segments instead of naive prefix matches.

• Several SECURITY DEFINER database functions have constrained search_path settings, and anon/authenticated execution was not granted for the inspected sensitive functions.

These are meaningful design strengths, but they do not prove all application routes, admin screens, environment variables and production release are safe. The app layer uses service-role credentials, so every route that calls the service client must independently authenticate, authorize and validate its input.

5.2 Findings

HIGH / SEC-01 Supabase leaked-password protection is disabled

Evidence: Supabase security advisor explicitly returned `auth_leaked_password_protection` WARN; protection against compromised passwords via HaveIBeenPwned is disabled.

Impact: A user might choose an already compromised password. This matters for the privileged administrator sign-in surface.

Required action: Enable leaked-password protection in Supabase Auth settings. Review password policy, MFA for super-admins, magic-link/OTP expiry, redirect allow-list and account recovery settings.

Acceptance test: Supabase advisor warning clears; admin sign-in/recovery and MFA flows pass acceptance tests.

HIGH / SEC-02 Vercel reports several secret entries with `readable-secret` metadata

Evidence: Environment-variable metadata flagged entries such as POSTGRES_PASSWORD, SUPABASE_SERVICE_ROLE_KEY, SUPABASE_JWT_SECRET, POSTGRES_PRISMA_URL, POSTGRES_URL, SUPABASE_SECRET_KEY and POSTGRES_URL_NON_POOLING. Values were not decrypted or reproduced. Several privileged variables target development, preview and production; SUPABASE_SERVICE_ROLE_KEY had multiple Preview entries.

Impact: This is a reason to investigate Vercel's secret handling/permissions and exposure scope. The metadata alone does not prove that the values were publicly exposed.

Required action: Review Vercel's exact security issue details and who can access/reveal these variables. Remove duplicate/obsolete key entries, use one naming convention, scope privileged credentials to server runtime and production only where feasible, restrict Preview access and untrusted PR execution. Rotate any credential that was exposed or whose exposure cannot be ruled out.

Acceptance test: An owner-led secret review records all current variables by target, owner and purpose; no service-role/password/JWT-secret key is exposed to browser bundles or untrusted Preview builds; relevant warning flags are resolved or accepted with written evidence.

HIGH / SEC-03 Main's admin gate is not production-ready and its required token is absent from Vercel metadata

Evidence: Main `src/lib/security/admin-gate.ts` uses `x-iwacu-admin-token` and requires `ADMIN_WRITE_TOKEN`. The inspected Vercel env-name list did not include `ADMIN_WRITE_TOKEN`; main's health route treats it as a required check. Security branch replaces this with Supabase Auth session/profile validation.

Impact: Main's admin writes fail closed with HTTP 503 when the token is missing; if the token model is enabled casually, it lacks per-user identity and scope accountability compared with verified Supabase Auth.

Required action: Do not ship main's legacy gate. Merge and test the reviewed Auth-based gate, server-validated admin profile, exact scope guard, and super-admin-only national access. Add MFA and authorization tests.

Acceptance test: On the release SHA, unauthenticated requests receive 401, authenticated non-admins receive 403, admins can only edit/reveal within their scope, and all denial cases are tested against the deployed environment.

HIGH / SEC-04 Backup tables are flagged by Supabase security and performance advisors

Evidence: `public._bak_boundaries_geom` and `_bak_boundaries_meta` have RLS enabled but no policies, and both lack primary keys. Advisor severity is INFO; direct grants in the inspected list were service_role-specific.

Impact: Unnecessary backup tables enlarge the privileged data footprint and may be confusing during recovery; no policy means browser access is denied by RLS, but the tables still deserve explicit ownership and lifecycle decisions.

Required action: Confirm whether the backup is still needed for rollback. If retained, document purpose/retention and verify all role grants explicitly; if not needed, make a controlled backup and remove it through a reviewed migration. Do not drop before recovery needs are confirmed.

Acceptance test: Security advisor and grants are reviewed after the owner approves a retention/cleanup plan; restore procedure remains tested.

MEDIUM / SEC-05 Unused indexes are reported, but should not be deleted blindly

Evidence: Supabase performance advisor reports 13 unused indexes. The database was created/imported very recently, so a low usage count is expected in a young project.

Impact: Removing useful indexes too early may degrade spatial hierarchy or administrative queries later.

Required action: Recheck after representative production-like read/query load; record query plans and keep indexes needed for spatial and scope lookups.

Acceptance test: A documented performance test and query-plan review justifies every index removal or retention decision.

HIGH / SEC-06 Sensitive admin actions lack demonstrated end-to-end authorization tests

Evidence: The security branch tests `admin-gate` and smoke tests unauthorized raw-phone reveal and PATCH; this does not cover every role, scope, HTTP method or API route.

Impact: A single missed route guard or scope mismatch could expose contact details or allow unauthorized changes.

Required action: Build a route-by-route authorization matrix for GET/PATCH/POST/DELETE, scope parent/child/sibling cases, national scope, phone reveal and report details. Test with anonymous, standard authenticated, scoped admin and super-admin sessions.

Acceptance test: Tests prove least privilege for each route and prevent cross-scope access, including a prefix-lookalike case such as `RW-01` versus `RW-010`.

6. Product logic, APIs and data integrity

6.1 AI Search: actual implementation versus label

The `AiSearchAssistant.tsx` user interface is labeled 'AI Search & Assistant' and contains suggested questions. The inspected `/api/ai-router/route.ts` does not call Gemini or Groq; it normalizes query text, removes stop words, chooses a likely administrative level and asks the public NISR GIS endpoint for matching places. It then looks for leader records by scope code. The route contains no LLM generation call. The repository manifest includes `@google/genai` and `groq-sdk`, but installed dependencies do not demonstrate model integration; the current route is the decisive evidence. The security-branch privacy page also states that the version does not connect conversations to an AI/LLM.

The previous Gemini audit's statement that a live Gemini 3.8 Flash engine answers Kinyarwanda leader questions and creates leader cards is unsupported by the code that was inspected. At best this is a place-name search/assistant; it is not a general question-answering engine and it should not invent leaders or official facts.

HIGH / APP-01 AI is an unsubstantiated product claim; actual search is heuristic place lookup

Evidence: Current route `src/app/api/ai-router/route.ts` uses token matching and the NISR place boundary service; it does not import or invoke a model. Query phrases suggesting leader-name search are not implemented as a reliable leader-name index.

Impact: Users may expect factual, broad Kinyarwanda answers and get a location match instead. A fuzzy/ambiguous query can return the first feature rather than explaining ambiguity.

Required action: Either rename the feature honestly as 'Shakisha aho hantu / Search places and leaders' and describe supported queries, or implement a genuine LLM only after grounding responses in verified database results, source references, uncertainty and no-fabrication constraints. Add ambiguity resolution and rate limits.

Acceptance test: A test matrix of Kinyarwanda and English queries records expected outputs; ambiguous place names ask the user to choose; unsupported questions refuse clearly; no unverified leader name/contact is emitted. UI wording matches the implementation.

6.2 API route review

CRITICAL / APP-02 Main's inactive-number report route uses process-memory mock storage

Evidence: Main `src/app/api/report-number/route.ts` calls `addMockInactiveReport`, `getMockInactiveReports` and `resolveMockInactiveReport`. Security branch replaces this with durable Supabase writes and super-admin-only access.

Impact: Serverless/in-memory data is not durable or shared across instances. A citizen can receive a success response even though a report may disappear on restart or another instance.

Required action: Merge the durable Supabase-backed implementation from the security branch. Confirm RLS/grants deny browser access; restrict report reads/resolution to verified super-admins; add abuse limits and retention policy.

Acceptance test: POSTed reports persist after redeploy/restart and are visible only to authorized admins; resolved/dismissed records have actor/time; rate-limit and validation tests pass.

HIGH / APP-03 Health checks on main can return HTTP 200 when degraded

Evidence: Main `/api/health` checks env presence and returns HTTP 200 regardless of missing values; security branch tries a minimal DB connectivity check and returns 503 on degraded status.

Impact: Monitoring systems may mark a broken deployment healthy, hiding missing environment configuration or database connectivity failures.

Required action: Merge the non-sensitive health implementation; keep credential names/status only and do not return secret values or detailed driver errors. Add readiness versus liveness semantics.

Acceptance test: With a deliberately missing/invalid dependency in a Preview environment, readiness returns 503/degraded; when healthy it returns 200; no secrets or PII appear.

HIGH / APP-04 Leader search is untestable as a working directory until verified records exist

Evidence: Place search fetches leaders only by known hierarchy scope codes; live `leaders` count is zero. The route intentionally returns no verified leader details if none are present.

Impact: The UI may demonstrate location lookup but cannot prove the end-to-end contact workflow or administrator content management against real records.

Required action: After data governance approval, implement a representative pilot set and test create, update, version conflict, deactivation, masking, explicit phone reveal, call/WhatsApp action and stale/duplicate scope handling.

Acceptance test: A real, approved test record flows from admin create to public lookup, hides contact information by default, reveals only after authorized action, and disappears from active results when deactivated.

MEDIUM / APP-05 API abuse/rate limiting remains an explicit residual risk

Evidence: The repository's own security audit says rate limiting on `/api/locate` and `/api/ai-router` should be added before public launch; no edge rate-limit implementation was found in the inspected files.

Impact: Open endpoints can be abused to create outbound NISR traffic, consume server resources or submit report spam.

Required action: Add provider/edge rate limits, request-size bounds, timeouts, sensible caching for public administrative lists, abuse alerts and an emergency shut-off procedure. Ensure retry logic is bounded.

Acceptance test: Load and abuse tests demonstrate per-client limits, predictable 429 responses, no unbounded request amplification and alerts for threshold breaches.

6.3 Request validation and correctness tests

• GPS endpoint has Zod validation for latitude, longitude and positive accuracy, an accuracy cutoff and a Rwanda bounding-box shortcut; that is good input hygiene, but physical field accuracy remains unverified.

• Administrative-unit and AI lookup depend on the public NISR FeatureServer. Network/service failures, timeouts, partial source coverage and same-name ambiguity need explicit tests and user-friendly recovery.

• The optimistic concurrency path must be tested for simultaneous edits, safe conflict payloads and atomic updates. A version pre-check alone can race; the actual UPDATE must also condition on version and detect a zero-row update.

• The `leader_role` enum covers a limited role list. Confirm whether every required national/local office level can be represented, including roles needed at province and cell level, and prevent invalid role-to-boundary combinations.

7. Geospatial coverage, offline behavior and PWA

7.1 Online geolocation

The `/api/locate` handler validates GPS values, rejects accuracy worse than 150 m, checks a rough Rwanda bounding box, asks the PostGIS confidence function and uses an NISR 2022 boundary-service fallback when the database has no match or the RPC fails. The source fallback calculates intersection between an accuracy circle and returned village polygons and explicitly reports a gap rather than fabricating a village. This is a sensible conservative design pattern, but the entire workflow needs real device tests; no direct live Android GPS test was performed as part of this audit.

7.2 Offline gaps

The tracked file `public/offline/gasabo-boundaries.geojson` contains `features: []` and its own note says it intentionally contains no made-up polygons and that the full national GeoJSON must be generated. Therefore the tracked asset itself cannot resolve any offline point. `public/manifest.json` references `/icons/icon-192.png` and `/icons/icon-512.png`, while a repository listing of `public/icons` returned 404. The service worker uses network-only API calls and only falls back to cached resources after they have been cached; it does not populate the empty boundary dataset on install.

HIGH / GEO-01 Offline geolocation cannot work from the committed boundary asset

Evidence: The committed Gasabo GeoJSON has an empty feature list. Full national boundary data is generated by a local script and is not automatically committed by that script, according to DEPLOYMENT.md.

Impact: A user with no internet can be left with cached UI but no polygon data to identify the location. Repository docs' offline claims overstate what ships by default.

Required action: Choose a realistic offline scope and size budget. Either ship and version verified offline polygons, or explicitly present offline as unavailable and never suggest it will resolve a location. For a national dataset, measure asset size, update frequency, memory, browser storage and license.

Acceptance test: On a fresh device with airplane mode enabled, the documented offline feature passes an end-to-end test using only bundled/cache data; otherwise the app clearly states it needs internet. No fake/sample location is shown.

HIGH / PWA-01 Manifest references missing icons

Evidence: Manifest references `/icons/icon-192.png` and `/icons/icon-512.png`; the repository does not contain the `public/icons` directory.

Impact: Install prompts, app launch icons or browser PWA checks can fail or fall back to broken assets.

Required action: Create branded 192x192 and 512x512 PNG icons, verify maskable safe zones, add them to version control and check manifest MIME/path handling.

Acceptance test: Both URLs return the intended image, manifest validation passes, and install is tested on at least one Android browser.

HIGH / GEO-02 Source data is from 2022 and known areas may be missing

Evidence: NISR's official layer metadata states the data is based on 2022 mapping, covers 14,816 of 14,837 gazetted villages, and does not guarantee every gazetted village has a mapped polygon.

Impact: A location can be misrepresented as complete/precise when the source is incomplete or administrative structures have changed since the source year.

Required action: Display source year/limits when relevant, record a last-verified date, create an update/reconciliation process with official authorities, and preserve uncertainty rather than forcing 100% confidence.

Acceptance test: Field tests and source-reconciliation report are accepted by the owner; no unsupported nationwide 100% claim remains; missing areas and error states are exercised.

7.3 Device test matrix required

• Android Chrome: GPS permission allowed, denied, permanently blocked, timeout, low accuracy, no signal indoors, airplane mode and location outside Rwanda.

• Boundary cases: point near village edges, shared borders, overlapping shapes, missing polygons, rural vs urban, Lake Kivu areas identified as excluded by source metadata.

• PWA: first visit, repeat visit, service-worker update, stale cache purge, missing/slow network, app installed and browser storage cleared.

• Accessibility: screen reader names, focus order, text contrast, large tap targets, keyboard operation, reduced motion, low-end phone memory and slow connections.

8. Emergency information, privacy and user trust

8.1 Emergency numbers

Official Rwanda government and Police pages currently list 112 for general emergency, 111 for fire and rescue, 113 for traffic accidents, 912 for ambulance, 116 for child help and 3512 for gender-based violence. The main-branch `/api/emergency` route instead labels 113 as fire, 114 as traffic, and 3512 as health information. These are not just stylistic differences; a wrong category could delay a citizen seeking help. The inspected security branch has updated labels for 111, 113 and 3512, but this change still needs to be merged into the release branch and the entire list rechecked against official sources before launch. Official references are listed in Section 13.

CRITICAL / OPS-01 Emergency labels in main contain incorrect mappings

Evidence: Main `src/app/api/emergency/route.ts`: 113 = fire, 114 = traffic, 3512 = health info. Official Rwanda government and RNP sources list 111 = fire, 113 = traffic, 3512 = gender-based violence; government pages list 114 as a health-services/call-centre number.

Impact: Citizens may call the wrong service during an emergency. This is a safety-critical defect.

Required action: Merge and independently re-verify every item against government source pages, set precise names in Kinyarwanda and English, distinguish general emergency from specialist hotlines, and record source + checked date. Do not include unverified numbers.

Acceptance test: Two reviewers verify all numbers from primary sources. Automated tests assert each number/category mapping; UI call links dial the listed number and the last-verified date is maintained.

8.2 Privacy / legal readiness

The security branch adds `/privacy` and properly says its notice is not legal certification. It says GPS is used only when requested, place-search terms or location fallback may be sent to NISR, inactive-number reports are stored, the leader directory has no verified active rows and a privacy contact/retention policy/formal legal review remain incomplete. These disclosures are sensible, but the wording, links, actual data flows, logging and retention must match production configuration.

- Create a real contact channel for privacy requests and incident reports; state retention periods for submitted reports, admin records, access logs and backups.
- Document who is data controller/processor, lawful basis, consent or notice flows, cross-border processing/hosting, data-subject request handling and retention deletion process with qualified local review.
- Test that location coordinates/query strings are not unnecessarily logged, retained in analytics or included in third-party AI prompts. Never claim law compliance solely because a checklist exists.
- Review public GitHub files under `public/assets/aistudio/` and `.aistudio/`, including project specification PDFs and screenshots, to confirm they contain no personal, operational, or unreleased information that should not be publicly distributed.

8.3 User-interface and trust issues

- Keep place-search, GPS locate and leader-contact paths distinct and understandable. Do not imply a returned place is a verified leader or a fully confirmed GPS point.
- The current mock-data module contains illustrative names, government-looking email addresses, contact numbers, dossiers and verification claims (for example sample leader records). Keep mock data isolated from any production code path and visibly mark it as test-only; never present it as real public-office data.
- Ensure error states cover no leaders, no matching polygon, duplicate place names, network outage, stale boundary source, unauthorized admin, conflict and report submission failure.

9. Reconciliation with the prior Gemini audit

The pasted Gemini report should be treated as an unverified narrative, not as test evidence. Below is a direct reconciliation against the repository, Supabase and Vercel evidence inspected for this report.

Previous claim	Independent finding	Disposition
'Fully functional' leader cards, with named officials and contact details	Live Supabase `leaders` table has 0 rows. Search route fetches only database rows. The names in `mock-data.ts` are fixtures, not verified active leaders.	**NOT PROVEN; core feature blocked**
'Gemini 3.8 Flash' AI answers Kinyarwanda questions 100%	Inspected `api/ai-router` uses token matching and NISR FeatureServer lookups; no LLM call is present in that route. Security privacy page says current version does not connect to AI/LLM.	**CONTRADICTED BY CODE**
'Zero lint errors' / high code quality verified	We did not run lint against the deployed source. CI workflow does not run lint. A successful build and typecheck do not prove zero lint errors.	**UNSUPPORTED CLAIM**
'National/offline fallback is production-grade'	Committed offline GeoJSON has zero features; manifest icon files are absent; official source coverage is limited and needs count reconciliation.	**CONTRADICTED / INCOMPLETE**
'RLS and audit logs are completely enforced'	RLS and grants show some good safeguards; however backup tables trigger advisor findings, `audit_logs` is empty, and no audit-event triggers were found in the database trigger inventory.	**PARTIALLY SUPPORTED**
'Pre-production / late MVP phase 3.5'	A subjective maturity label is not a release gate. There is no active leader data and the latest Vercel target is not shown as Production.	**NOT EVIDENCE-BASED**
'No fabricated data is shown'	API paths generally try not to return fake public records, but `mock-data.ts` contains illustrative leaders/dossiers with official-looking contact and verification claims. These must not leak into production flows.	**REQUIRES END-TO-END PROOF**

Fair conclusion: the prior audit did identify meaningful architectural components, but it overstated proof of readiness. This audit distinguishes code presence from runtime behavior, database structure from populated official data, and a READY Preview build from a verified Production release.

What the prior audit gets partly right

The project has a substantive codebase: Next.js/React UI, place lookup, a PostGIS confidence path, administrative API routes, RLS policies, a public leader view that omits phone_number, a service worker and an admin portal. These are capabilities implemented or scaffolded in code. The outstanding question is whether each one is coherently connected, configured for the intended release, supplied with verified data, and tested in the exact production environment.

10. Prioritized remediation roadmap

Work in this sequence. Do not start with visual polishing or claim launch readiness while P0 blockers remain. The order avoids duplicate work and reduces the risk of damaging the working Preview branch.

P0 - Must close before any public launch

Step	Required work	Definition of done
0.1	Select a single canonical release commit. Review security/part-2-auth-hardening into main through a pull request; preserve history and inspect conflicts.	main contains reviewed security fixes; required CI passes on the final merge SHA; no feature is Preview-only.
0.2	Promote that exact SHA to Vercel Production and verify production domain/configuration.	Deployment has target=production; public domain maps to it; health/readiness works externally; rollback target is documented.
0.3	Load and verify authoritative leader records for the initial launch geography.	Approved provenance, current scope code/role, confirmation date and contact policy for each record; public lookup and contact actions pass tests.
0.4	Correct and source-check all emergency contact names/numbers in the release branch.	112/111/113/912/116/3512 verified from official sources; any 114 health-services listing is clearly separated if included; tests pin every label.
0.5	Run critical mobile end-to-end tests from a clean device/browser and real Preview/Production.	GPS, manual search, leader card, call/WhatsApp, admin login/edit, report submit/review, errors and unauthorized attempts all pass; logs retained.

P1 - Required before broad public promotion

Step	Required work	Acceptance evidence
1.1	Resolve Supabase/Vercel security findings: leaked-password protection, credential scope, duplicate variables, auth/MFA and audit trail.	Advisors are clean or findings are formally accepted; secret target inventory reviewed; scoped-auth tests and audit event tests pass.
1.2	Reconcile official boundary data and publish source/import manifest.	Source version, counts, IDs, checksums, missing areas and known exclusions are recorded and independently sampled.
1.3	Make AI/search feature wording honest; improve ambiguity and query coverage; add limits.	Supported-query matrix passes; ambiguous places prompt a choice; unsupported questions cannot invent people or officials.
1.4	Fix offline/PWA story, empty GeoJSON and missing icons; validate service-worker lifecycle.	Either verified offline data works on a fresh phone, or offline limitations are explicit; icons/manifest validate.
1.5	Add full API authorization matrix, request validation, rate limits and monitoring.	All APIs have route tests; cross-scope access is blocked; abuse rate-limited; alerts tested.
1.6	Complete privacy/data governance review and incident/recovery exercises.	Privacy contact/retention/processor map and legal review documented; backup restoration/rollback proven.

P2 - Maintainability and scale

• Normalize DEPLOYMENT.md/README/SECURITY_AUDIT.md to the real architecture and migration workflow; remove nonexistent script instructions and stale 'MVP is live' language.

• Use one canonical database migration history. Do not re-run an old schema.sql over a database whose live state is already governed by 16 applied migrations; test changes on a clone before production.

• Add accessibility, slow-network, performance, SEO, browser compatibility and load tests; collect production metrics before dropping 'unused' indexes.

• Review public repository assets and code fixture separation; document ownership, data backup policy, alert escalation, support contacts and recovery runbook.

11. Release acceptance test matrix

Do not mark a feature complete merely because a component or API route exists. Use explicit input, expected result, security expectation and stored evidence for every test below.

ID	Test	Pass condition	Owner evidence
T-01	Production identity	Domain, branch and commit SHA equal approved release; production-targeted deployment READY.	Vercel deployment URL + SHA
T-02	Health/readiness	Healthy state returns 200; missing DB/config state degrades with non-sensitive 503.	HTTP capture + sanitized logs
T-03	Place search	Known exact place resolves; repeated/same-name query returns choices or safe explanation; unknown name is not fabricated.	Query matrix report
T-04	Leader results	Only verified active records appear, with correct jurisdiction and contact actions.	Approved sample reconciliation
T-05	GPS precision	Permission, timeout, poor accuracy, gap, border overlap and source failure give correct non-fabricated states.	Real Android test log
T-06	Admin authentication	Anonymous denied; non-admin denied; scoped admin can edit own scope only; super-admin can access allowed nationwide actions.	Role/scope test report
T-07	Phone reveal	Phone masked by default; explicit reveal restricted to one leader and authorized scope; no raw phone in conflicts/logs.	API assertions + log review
T-08	Concurrency	Two admins edit same version; one wins, other gets 409 with no raw sensitive data; no lost update.	Automated concurrency test
T-09	Inactive-number report	POST persists across restart; only super-admin can list/resolve/dismiss; repeat/stale resolution safe.	Database before/after + API test
T-10	Emergency directory	Every displayed number has verified official label and works as a tap-to-call target.	Source register + handset test
T-11	Offline/PWA	Install icons work; online/offline transitions are truthful; no empty cache is presented as working GPS.	Fresh-browser airplane-mode test
T-12	Security abuse	Rate limiting, oversized bodies, invalid enums/codes, route auth and cross-scope access are rejected safely.	CI test output + rate-limit logs
T-13	Recovery	Restore from backup and rollback to last production release within documented objectives.	Rehearsal log and owner sign-off

Release gate: every P0 finding closed, all P1 items closed or explicitly risk-accepted by the project owner, and T-01 through T-13 pass against the exact candidate release. A green build alone is not the release gate.

12. Database migration and operational consistency

The live Supabase database shows 16 applied migrations, including base schema, security hardening, private RBAC helpers, public grants, report persistence/permissions and a national-scope super-admin restriction. Main's tracked `sql/schema.sql` still reflects an older schema/policy design (including the earlier public leader policy and in-memory report route elsewhere in the app). The security branch has a more current schema file and additional SQL migration files. Do not treat main's old schema.sql as an idempotent production migration.

HIGH / DB-04 The live database and main's canonical schema documentation have drifted

Evidence: Live migration ledger lists 16 changes through `admin_national_scope_requires_super_admin`; main tracked schema.sql is an older base-style script while security branch contains additional schema hardening and migration files.

Impact: A developer following the old deployment guide may reset/overwrite policies or reintroduce a vulnerable path, or fail to reproduce the live database in a clean environment.

Required action: Use numbered immutable migration files as the only deployment source of truth. Generate or maintain a clean database bootstrap procedure, run migrations in staging, test forward and rollback/restore, then update the docs. Never execute a broad old schema script blindly on the existing production database.

Acceptance test: A clean disposable Supabase project can be built from committed migrations to the same schema/policies as audited live project; migration state matches the approved Git commit.

Recommended live-database safeguards

• Before any production migration, export schema and data backups, review the exact SQL diff and confirm it is safe to rerun or explicitly non-rerunnable.

• Add migration parity checks: applied migration list vs committed migration files vs actual schema (tables, columns, policies, grants, views, functions and extensions).

• Keep `service_role` key in server-only environments; ensure no public/browser bundle can import the server service client.

• Record a provenance/source version for every boundary import and an approval/version for every leader import; keep rollback/restore instructions tested.

• Reconcile report persistence on main with the live `inactive_number_reports` table and the security branch code before selecting the release SHA.

Exact state evidence captured

Evidence item	Observed value
Supabase migration count	16 applied migrations; most recent name `admin_national_scope_requires_super_admin` (version 20261029211402).
PostgreSQL	17.11.0.003 / major version 17
Extensions confirmed installed	PostGIS 3.3.7, ltree 1.3 in extensions schema, pgcrypto 1.3, uuid-ossp 1.1; additional standard Supabase extensions are present.
RLS and grants	RLS enabled; inspected policies and grants show direct browser table access is restricted, public active-leader view is granted SELECT, and report table is denied to browser roles.
Backup tables	_bak_boundaries_geom 17,423 rows; _bak_boundaries_meta 1 row; no PK/policies per metadata/advisors; service_role-only grants observed.
Edge functions	No Supabase Edge Functions returned for this project; API logic is in Next.js/Vercel routes.

13. Documentation, source governance and observability

MEDIUM / DOC-01 Repository setup instructions are stale or contradictory

Evidence: README and DEPLOYMENT.md describe a Gasabo MVP while the current database includes national boundary rows. README references `npm run seed:leaders`, but no matching script appears in the inspected package.json. The deployment guide ends with 'You are done. The MVP is live.' despite unmet production gates.

Impact: The next developer or AI may repeat completed tasks, run the wrong seed/import process or falsely assume the live release is complete.

Required action: Rewrite docs against the actual approved architecture and code: branch, migration flow, supported offline scope, actual AI/search behavior, data source limitation, required env var names by environment, leader import governance, health checks and rollback. Remove premature claims.

Acceptance test: A new technician can build from a clean clone and staging DB using only the docs; scripts referenced by docs exist and pass; docs disclose all non-automatic data steps.

MEDIUM / DOC-02 Repository includes public Studio artifacts that need content review

Evidence: The public repository tree includes `.aistudio` temporary-media artifacts and `public/assets/aistudio/` screenshots and project specification PDFs.

Impact: Internal screenshots, unpublished design notes or personal details may be public unintentionally. No actual secret exposure was established from metadata alone.

Required action: Review each committed artifact and ensure it is intended for public distribution. Remove private/unreleased material after owner approval and scan Git history for any actual credentials or private data before publishing further.

Acceptance test: The project owner signs an inventory of intentionally public files; secret scan returns no active credential; any exposed credentials are rotated.

Operational capabilities to finish

• Define uptime, latency, error-rate and abuse alerts. The application needs a named person/channel to receive alerts and take action.

• Keep logs privacy-minimized: no tokens, raw phone values, full coordinates, sensitive report comments or credentials. Set log retention and inspect failures after release.

• Define daily/weekly database backups, restore time objective, data loss objective and a tested recovery process. Keep rollback possible without deleting new citizen reports or leader records.

• Use an agreed production/preview separation: preview is test-only, no untrusted pull request receives production secrets, and a release does not silently happen from an experimental branch.

• Document data freshness: who validates an official leader change, how the citizen reports a wrong number, who resolves it, what is shown while a report is pending and how disputes are recorded.

Official source checks for emergency numbers

Rwanda's official government emergency page lists 112 emergency, 113 traffic accidents, 114 health services, 116 child helpline, 912 ambulance and 3512 gender-based violence; Rwanda National Police lists 112 emergency, 113 traffic accidents, 111 fire and rescue and 3512 gender-based violence. Use the primary source relevant to each service and keep a review date. Sources checked on 30 October 2026: Government of Rwanda - Emergency Numbers and Rwanda National Police - FAQ / emergency toll-free numbers.

NISR Village Boundary 2022 source: official layer metadata and layer description. Its metadata reports 14,816 mapped villages out of 14,837 gazetted and provides context about the data vintage; the app must preserve these limits.

14. Final release recommendation

DO NOT ANNOUNCE THE PLATFORM AS COMPLETE OR NATIONWIDE-READY YET. The database schema and source code show substantial groundwork, but core leader data and production release evidence are missing, and the audited default branch is behind the current security Preview branch.

Owner sign-off checklist

- [ ] One reviewed GitHub main SHA is selected; Preview-only code is merged through PR and required tests pass.
- [ ] The exact approved SHA is running on Vercel Production with the intended verified domain, working health check and rollback plan.
- [ ] Real leader records for the launch area are verified, approved and present; all mock/dummy names and contacts are excluded from production.
- [ ] Boundary-source count discrepancy is reconciled and official missing-coverage limitations are disclosed.
- [ ] Emergency-number mappings are independently checked and automated tests lock the correct label for each number.
- [ ] Supabase password protection, RLS/grants, secret handling, MFA, rate limits, audit events and per-route authorization are reviewed and tested.
- [ ] GPS and location-search have passed real-device field tests; no fabrications occur for gaps, ambiguous names, or service failure.
- [ ] Offline/PWA features are either proven on a fresh offline handset or explicitly documented as online-only; manifest assets are present.
- [ ] Privacy notice, data retention, contact channel, backup restore and incident response have named owners and evidence.
- [ ] Tests T-01 through T-13 pass for the exact production candidate; residual risks are documented and accepted by the owner.

Final assessment

Current status is best described as a substantial pre-production implementation with a structurally populated national boundary database, a leader directory that has not yet been populated, a security-enhanced branch ahead of main, and a READY but not demonstrably Production-targeted Vercel deployment. There is not enough evidence to certify full live functionality, full national coverage, or production readiness.

No modifications were made

This audit was conducted read-only. No GitHub file was changed, no commit or push was made, no database row/schema/policy was changed, no Vercel setting/environment variable/deployment was modified, and no secret values were decrypted or reproduced. The public deployed site could not be independently exercised in a browser from this audit environment, so runtime UI and phone behavior remain an explicit verification task.

15. Evidence register and references

Platform snapshots

R1 - GitHub repository metadata and main commit - github.com/eddyizere24-collab/Iwacu-rwanda-2
Repository is public, default branch main; main SHA c6c01cbd3a24fea53df7f0fe1b0600dca58e137b.

R2 - Security branch head - github.com/eddyizere24-collab/Iwacu-rwanda-2/tree/security/part-2-auth-hardening
SHA 94ff01f598356991e841e0cb43a05def0b5a6a5a; branch was 117 commits ahead of main at audit time.

R3 - Latest inspected Vercel deployment - vercel.com/ahabona/iwacu-rwanda-2/AoLWpAsabxNpwQihe9jHG1WgWVMD
Deployment dpl_AoLWpAsabxNpwQihe9jHG1WgWVMD; READY, target null; commit 94ff01f... on security/part-2-auth-hardening.

R4 - Supabase project dashboard - supabase.com/dashboard/project/buexgewxypvkqmphvfec
Project ref buexgewxypvkqmphvfec; ACTIVE_HEALTHY; PostgreSQL 17.11; database inventories/advisors/SQL executed read-only.

R5 - GitHub Actions security workflow - github.com/eddyizere24-collab/Iwacu-rwanda-2/actions
One successful run for commit 94ff01f...; typecheck, security-gate tests, build and three preview HTTP checks; not full E2E.

R6 - Main source: AI route - github.com/eddyizere24-collab/Iwacu-rwanda-2/blob/main/src/app/api/ai-router/route.ts
Tokenized location/place matching through NISR GIS; no LLM call in the inspected route.

R7 - Main source: reports route - github.com/eddyizere24-collab/Iwacu-rwanda-2/blob/main/src/app/api/report-number/route.ts
Uses in-memory mock report helpers on main; security branch has a persistent Supabase implementation.

R8 - Offline GeoJSON asset - github.com/eddyizere24-collab/Iwacu-rwanda-2/blob/main/public/offline/gasabo-boundaries.geojson
Tracked feature collection is intentionally empty (`features: []`).

R9 - Manifest - github.com/eddyizere24-collab/Iwacu-rwanda-2/blob/main/public/manifest.json
References /icons/icon-192.png and /icons/icon-512.png; no public/icons directory found in repository.

R10 - Main emergency route - github.com/eddyizere24-collab/Iwacu-rwanda-2/blob/main/src/app/api/emergency/route.ts
Mapping in main conflicts with official government emergency-number information.

Official external references (checked 30 October 2026)

R11 - Government of Rwanda emergency numbers: gov.rw/emergency. The page lists 112 emergency, 113 traffic accidents, 114 health services, 116 child helpline, 912 ambulance and 3512 GBV.

R12 - Rwanda National Police emergency FAQs: police.gov.rw/about-us/frequently-asked-questions. The page lists 112 emergency, 111 fire brigade, 113 traffic accident, 3512 GBV and other specialized numbers.

R13 - NISR Village Boundary 2022 feature service metadata: NISR service metadata. It says 14,816 mapped villages out of 14,837 gazetted and describes source vintage/coverage limits.

Evidence limitations and confidence

High confidence: repository contents/branch metadata; Supabase table/row counts, policy/grant/function/trigger inventories and database advisor outputs; Vercel project/deployment/environment metadata; official emergency-number source pages. Moderate confidence: code-level functional interpretation, because no fresh build was run locally and full tests were not performed in this audit. Not verified: public production UI in a browser, live device GPS, actual call/WhatsApp handoff, full login/admin journeys, complete official leader data accuracy and a formal penetration test.

Prepared for the project owner as an evidence-based engineering review. This is not a legal opinion, official NISR certification, or formal penetration-test certificate.